

SuperPlus -> entreprise de grande distribution qui souhaite :

- mieux comprendre le comportement de ses clients,
- suivre l'efficacité de ses campagnes marketing,
- tout en respectant les obligations du RGPD.

Cpdt, cette entreprise **collecte** et **conserve** de nombreuses DCP (identité, contacts, achats, préférences, ...).

➔ La direction s'inquiète des risques de non-conformité et attend de moi des solutions.

Données à disposition : 3 fichiers Excel : clients, achats, campagnes

client_id	nom	prenom	age	sexe	email	telephone	ville	carte_fidelite
1	Client1	Prenom1	32	H	client1@exemple.com	666506311	Lyon	VRAI
2	Client2	Prenom2	72	H	client2@exemple.com	645939823	Lille	VRAI
3	Client3	Prenom3	43	H	client3@exemple.com	642709176	Paris	VRAI
4	Client4	Prenom4	72	H	client4@exemple.com	628863900	Marseille	VRAI
5	Client5	Prenom5	55	F	client5@exemple.com	655922054	Toulouse	FAUX
6	Client6	Prenom6	63	F	client6@exemple.com	654635586	Paris	VRAI
7	Client7	Prenom7	30	H	client7@exemple.com	617104469	Marseille	FAUX
8	Client8	Prenom8	45	F	client8@exemple.com	676605315	Paris	VRAI
9	Client9	Prenom9	33	H	client9@exemple.com	654086742	Lille	VRAI
10	Client10	Prenom10	56	F	client10@exemple.com	643111837	Paris	VRAI
11	Client11	Prenom11	46	H	client11@exemple.com	699624163	Lyon	VRAI
12	Client12	Prenom12	51	F	client12@exemple.com	624515551	Lyon	VRAI
13	Client13	Prenom13	39	F	client13@exemple.com	673665675	Lille	VRAI
14	Client14	Prenom14	72	F	client14@exemple.com	618315457	Toulouse	VRAI
15	Client15	Prenom15	29	F	client15@exemple.com	646674334	Toulouse	VRAI
16	Client16	Prenom16	27	H	client16@exemple.com	637411181	Lyon	VRAI
17	Client17	Prenom17	50	F	client17@exemple.com	678637521	Paris	VRAI
18	Client18	Prenom18	67	H	client18@exemple.com	675292032	Toulouse	FAUX
19	Client19	Prenom19	35	F	client19@exemple.com	682092688	Paris	VRAI
20	Client20	Prenom20	20	H	client20@exemple.com	660010811	Lyon	VRAI

achat_id	client_id	date_achat	categorie	montant	campagne_associee
1	169	06/12/2023	Loisirs	236.78	
2	149	31/01/2023	Alimentation	44.72	5
3	6	17/10/2023	Hygiène	95.6	3
4	162	04/07/2023	Hygiène	234.43	2
5	51	19/11/2023	High-Tech	63.02	2
6	129	26/09/2023	Loisirs	221.3	2
7	148	27/05/2023	High-Tech	48.07	4
8	59	31/07/2023	Textile	265.54	5
9	49	27/03/2023	Alimentation	172.74	4
10	11	14/10/2023	Hygiène	32.7	2
11	177	21/08/2023	High-Tech	13.59	2
12	152	30/12/2023	Loisirs	12.42	4
13	177	15/01/2023	Hygiène	259.24	1
14	99	09/12/2023	Textile	286.24	2
15	11	21/03/2023	Alimentation	250.41	4
16	152	16/06/2023	Hygiène	275.51	2
17	8	23/11/2023	Loisirs	273.74	1
18	3	19/07/2023	Textile	36.97	4
19	179	04/08/2023	Textile	165.86	1
20	27	24/07/2023	Alimentation	114.29	

campagne_id	nom_campagne	canal	budget	objectif
1	Campagne_1	Application mobile	19429	Augmenter CA
2	Campagne_2	Email	14327	Recruter nouveaux clients
3	Campagne_3	SMS	13855	Recruter nouveaux clients
4	Campagne_4	Email	18643	Augmenter CA
5	Campagne_5	Email	9771	Augmenter CA

Missions : conformité RGPD et AIPD

- **Établissez une veille sur des décisions et/ou recommandations en matière de conformité dans le secteur de la grande distribution**

Dans le secteur de la grande distribution, la **CNIL** (Commission Nationale Informatique et Libertés) rappelle régulièrement l'importance du **respect du RGPD**, notamment concernant la collecte des données clients via les cartes de fidélité et les campagnes marketing ciblées. Les principaux enjeux concernent la transparence de l'information, la durée de conservation des données et le consentement pour les actions de prospection commerciale.

- **Identifiez les données personnelles dans les fichiers**

Dans le contexte du RGPD, une donnée personnelle est toute information se rapportant à une personne physique identifiée ou identifiable.

1. Clients

Colonne	Est-ce une DP ?	Justification
client_id	Oui	C'est l'identifiant technique qui relie toutes les informations d'achat à la personne physique.
nom, prenom	Oui	Ce sont des identifiants directs .
age, sexe, ville	Oui	Informations de profil qui décrivent la personne identifiée.
email, telephone	Oui	Ce sont des identifiants directs (coordonnées de contact).
carte_fidelite	Oui	Indique l'appartenance à un programme, toujours rattachée à l'identité.

2. Achats

Colonne	Est-ce une DP ?	Justification
achat_id	Non	C'est l'identifiant de la transaction, pas de la personne.
client_id	Oui	Clé de liaison indispensable pour identifier la personne qui a fait l'achat.
date_achat, montant	Oui	Révèlent le comportement d'achat (quand et combien), rattaché à une personne identifiable.
categorie	Oui	Révèle les préférences et habitudes de consommation (Loisirs, Hygiène, Textile), rattachées à la personne.
campagne_associee	Oui	Révèle l'interaction du client avec le marketing de l'entreprise, rattachée à une personne identifiable.

3. Campagnes

Colonne	Est-ce une DP ?	Justification
Toutes les colonnes	Non	Elles décrivent l'opération marketing (budget, objectif, canal), et non une personne physique.

• **Analysez les risques en réalisant une AIPD (Analyse d'impact relative à la protection des données) comprenant :**

➔ Réaliser une AIPD, c'est **évaluer les risques** qu'un traitement de données personnelles est susceptible d'engendrer sur les **droits et libertés des personnes concernées**.

◦ **description des traitements**

OBJECTIF : Mieux comprendre le comportement des clients, suivre l'efficacité des campagnes marketing et cibler les offres.

Données traitées :

- **Données d'identification** (nom, prénom, email, tel, client_id)
- **Données de profil** (age, sexe, ville, carte_fidelite)
- **Données de comportement/achat** (date_achat, categorie, montant, campagne_associee)

Flux : Collecte (via le formulaire d'adhésion/achat) -> Structuration / Nettoyage -> Analyse / Profilage (segmentation) -> Utilisation pour le ciblage des campagnes (email, sms, appli mobile)

Destinataires : équipe marketing, équipe data analysts (internes)

◦ **base légale des traitements (base légale = Qu'est-ce qui m'y autorise ?)**

- **Prospection commerciale (e-mail/SMS)** : Consentement de la personne. Pour la prospection par voie électronique (e-mail, SMS), le client doit avoir donné son accord libre, spécifique, éclairé et univoque.
- **Analyse du comportement et profilage** : Intérêt Légitime. L'entreprise a un intérêt économique légitime à mieux connaître ses clients pour optimiser ses offres, à condition que les intérêts et droits fondamentaux des clients ne soient pas outrepassés (nécessité d'un test de balance).

◦ **durée de conservation**

La durée doit être limitée à ce qui est nécessaire pour atteindre les finalités.

- **Données d'identification et de profil (clients actifs)** : Tant que le client est considéré comme actif (par exemple, 3 ans sans achat ou interaction avec la marque).
- **Données des prospects (non-clients)** : Généralement 1 à 3 ans après le dernier contact, sauf retrait du consentement.
- **Données anonymisées** : Peuvent être conservées plus longtemps à des fins statistiques.

◦ **transparence de l'information + exercice des droits**

Droit/Obligation	Mesure requise
Transparence/Information	Mettre à disposition une politique de confidentialité claire (mentionnant les finalités, les catégories de données, la base légale, les durées de conservation) lors de la collecte.
Droit d'Accès	Mettre en place une procédure simple pour permettre au client d'obtenir une copie de ses données.
Droit d'Opposition	Système d'Opt-Out facile et clair dans chaque e-mail/SMS marketing, permettant de se désabonner à tout moment.

Droit/Obligation	Mesure requise
Droit à l'Effacement	Mettre en place un processus pour l'effacement définitif des données, notamment suite à l'exercice du droit à l'oubli.

◦ **risques pour les personnes concernées**

Risque	Impact potentiel	Gravité
Atteinte à la vie privée / Profilage Excessif	Le profilage peut révéler des informations sensibles (préférences de vie, santé, situation financière via les achats) sans leur consentement éclairé.	Élevée
Fuite ou Accès Non Autorisé	Si les fichiers clients.png et achats.png sont compromis, cela mène à une usurpation d'identité ou à des tentatives de fraude (les données contiennent email, téléphone, nom, adresse) ¹⁶ .	Élevée
Discrimination	Un ciblage (ou une exclusion) automatique basé sur le profilage (âge, sexe, ville) pourrait entraîner une exclusion ou une discrimination involontaire dans l'accès à certaines offres.	Moyenne

Risque	Impact potentiel	Gravité
Non-respect du droit d'opposition	Le client continue de recevoir des communications après avoir exercé son droit de retrait.	Faible/Moyenne

- **mesures de protection techniques et organisationnelles etc (ex : anonymisation, limitation d'accès)**

Type	Mesure de protection proposée	Objectif
Technique (T)	Pseudonymisation des identifiants (remplacer le client_id interne par un jeton unique) dans les environnements d'analyse/statistique ¹⁸ .	Réduire le lien direct avec l'identité en cas de fuite.
Technique (T)	Chiffrement (Cryptage) des colonnes sensibles (email, telephone) dans la base de données de production.	Empêcher la lecture des identifiants en cas d'accès non autorisé à la base.
Organisationnelle (O)	Limitation d'accès (Principes du <i>Need-to-Know</i>) : Seuls les data analysts ayant besoin des données complètes pour leur mission y accèdent.	Réduire les risques internes de fuite ou d'utilisation abusive.

Type	Mesure de protection proposée	Objectif
Organisationnelle (O)	Sensibilisation et Formation des équipes marketing et data aux exigences du RGPD.	Réduire le risque d'erreur humaine et de non-conformité.
Organisationnelle (O)	Inventaire et Audit régulier des traitements et des accès.	Assurer le respect continu des mesures.

- **Formalisez l'AIPD sous la forme d'un schéma visuel ou d'un arbre de décision par exemple**

- **Appréciez le niveau de risques et proposez une ou des solutions**

I. Appréciation du Niveau de Risque

Le traitement de profilage de SuperPlus est associé à un **Risque Brut Élevé** en raison du croisement des **identifiants directs** (nom, email, téléphone) avec l'historique d'achat. La fuite de ces données entraînerait une **atteinte grave à la vie privée** et un risque d'usurpation d'identité.

Avec les mesures de protection adéquates, le **Risque Résiduel** est ramené à un niveau **Modéré**.

II. Solutions Proposées

Les solutions doivent se concentrer sur la **sécurité (technique)** et la **gouvernance (organisationnelle)** pour assurer la conformité :

Type	Solution Clé	Objectif
Technique	Pseudonymisation & Chiffrement	Rendre les données inexploitablees en cas de fuite et limiter l'accès à l'identité réelle.
Organisationnelle	Preuve de Consentement & Droits	Gérer rigoureusement le consentement pour le marketing électronique et garantir l'exercice facile du droit d'opposition et d'effacement.